

Ömer Karataş - 38160

Answer 0:

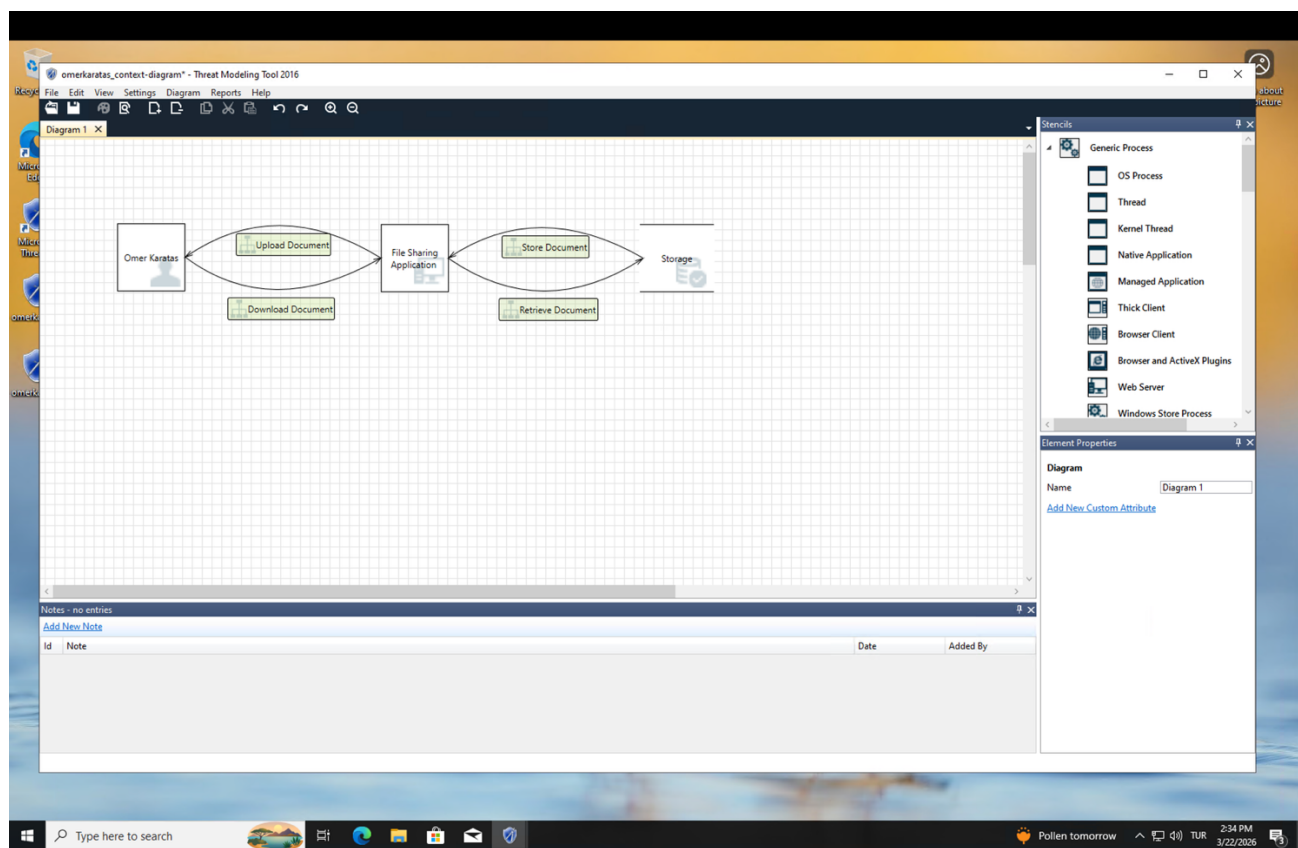
The screenshot displays the Microsoft Azure portal interface for a virtual machine named 'test'. The left sidebar shows the navigation menu with 'Virtual machines' selected. The main pane shows the 'Overview' tab for the VM, which is a Windows 10 Enterprise VM generation V2, architecture x64. The 'Networking' section shows a single public IP address (20.123.43.234) and a private IP address (10.0.0.4). The 'Size' section shows the VM is configured with Standard B2ts v2, 2 vCPUs, and 1 GiB of RAM. The 'Source image details' section shows the source image is MicrosoftWindowsDesktop, published by Microsoft, and the source image offer is Windows-10.

Section	Property	Value
Virtual machine	Computer name	test
	Operating system	Windows (Windows 10 Enterprise)
	VM generation	V2
	VM architecture	x64
	Agent status	Ready
	Agent version	2.7.41491.1209
	Hibernation	Disabled
	Host group	-
	Host	-
	Proximity placement group	-
Networking	Public IP address (IPv4)	20.123.43.234 (Network interface test502_x1)
	Private IP address (IPv4)	10.0.0.4
Size	Size	Standard B2ts v2
	vCPUs	2
Size	RAM	1 GiB
	Source image details	
Source image details	Source image publisher	MicrosoftWindowsDesktop
	Source image offer	Windows-10

The screenshot shows the Windows System Information window, displaying a list of system properties and their values. The window is titled 'System Information' and has a menu bar with 'File', 'Edit', 'View', and 'Help'. The 'System Summary' tab is selected, showing a list of system properties and their values.

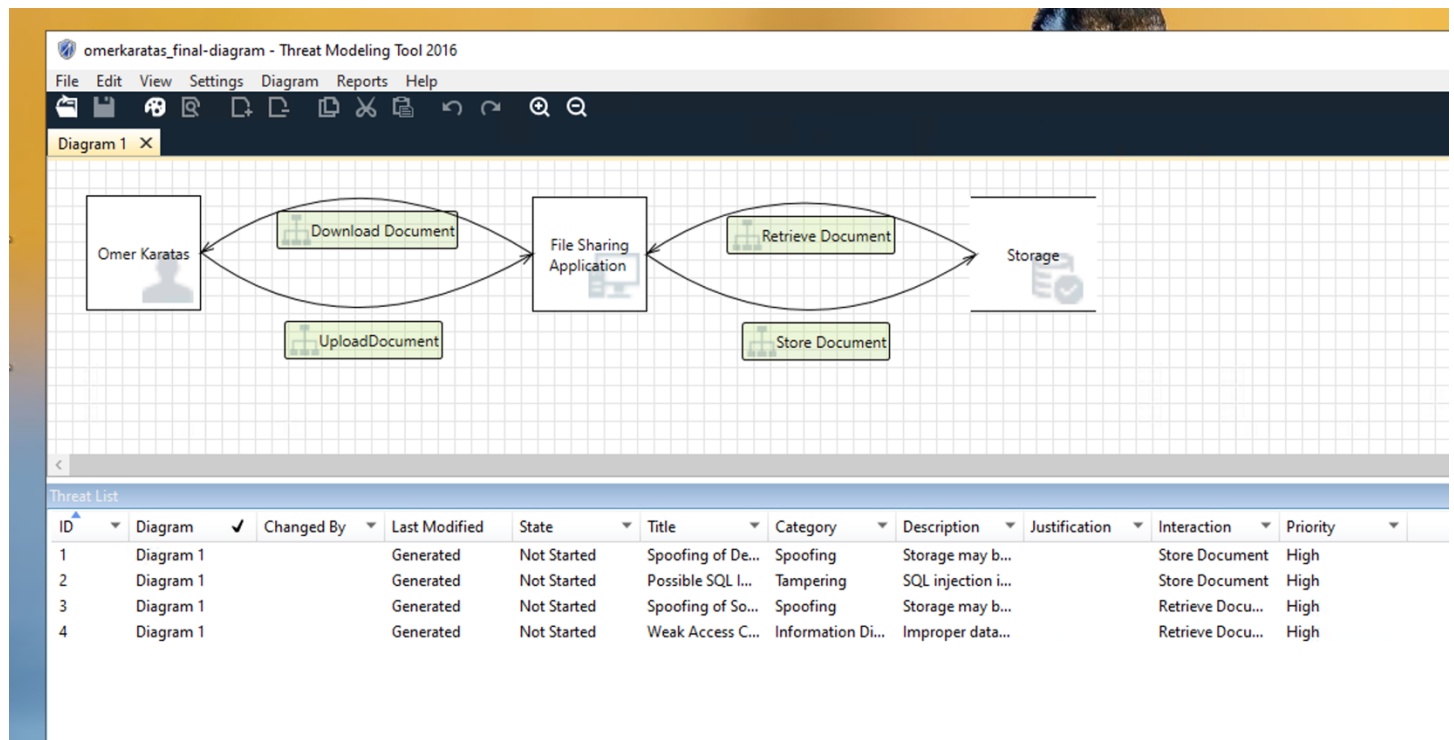
Item	Value
OS Name	Microsoft Windows 10 Enterprise
Version	10.0.19045 Build 19045
Other OS Description	Not Available
OS Manufacturer	Microsoft Corporation
System Name	test
System Manufacturer	Microsoft Corporation
System Model	Virtual Machine
System Type	x64-based PC
System SKU	None
Processor	Intel(R) Xeon(R) Platinum 8370C CPU @ 2.80GHz, 2793 Mhz, 1 Core(s), 2 Logic...
BIOS Version/Date	Microsoft Corporation Hyper-V UEFI Release v4.1, 1/14/2026
SMBIOS Version	3.1
Embedded Controller Version	255.255
BIOS Mode	UEFI
BaseBoard Manufacturer	Microsoft Corporation
BaseBoard Product	Virtual Machine
BaseBoard Version	Hyper-V UEFI Release v4.1
Platform Role	Desktop
Secure Boot State	Off
PCR7 configuration	Binding Not Possible
Windows Directory	C:\Windows
System Directory	C:\Windows\system32
Boot Device	\Device\Harddisk\volume3
Locale	United States
Hardware Abstraction Layer	Version = "10.0.19041.6456"
User Name	Not Available
Time Zone	Coordinated Universal Time
Installed Physical Memory (RAM)	1.00 GB
Total Physical Memory	1.00 GB
Available Physical Memory	19.7 MB
Total Virtual Memory	3.47 GB
Available Virtual Memory	609 MB
Page File Space	2.48 GB
Page File	C:\pagefile.sys
Kernel DMA Protection	Off
Virtualization-based security	Not enabled
Device Encryption Support	Reasons for failed automatic device encryption: TPM is not usable, PCR7 bindi...

Answer 1.1:



Answer 1.3:

There are 4 threats.



Answer 1.4:

Threat Count by STRIDE Category:

- **Spoofing:** 2 threats
- **Tampering:** 1 threat
- **Repudiation:** 0 threats
- **Information Disclosure:** 1 threat
- **Denial of Service:** 0 threats
- **Elevation of Privilege:** 0 threats

Answer 1.5:

The screenshot shows the Threat Modeling Tool 2016 interface. The top part displays a diagram titled 'Diagram 1' with three main components: 'Omer Karatas' (a user icon), 'File Sharing Application', and 'Storage'. The interactions are as follows: 'Omer Karatas' can 'Download Document' from the 'File Sharing Application' and 'UploadDocument' to it. The 'File Sharing Application' can 'Retrieve Document' from 'Storage' and 'Store Document' to it. Below the diagram is a 'Threat List' table with 4 threats displayed out of 15 total. The first threat is selected.

ID	Diagram	Changed By	Last Modified	State	Title	Category	Description	Justification	Interaction	Priority
1	Diagram 1		Generated	Not Started	Spoofing of De...	Spoofing	Storage may b...		Store Document	High
2	Diagram 1		Generated	Not Started	Possible SQL I...	Tampering	SQL injection i...		Store Document	High
3	Diagram 1		Generated	Not Started	Spoofing of So...	Spoofing	Storage may b...		Retrieve Docu...	High
4	Diagram 1		Generated	Not Started	Weak Access C...	Information Di...	Improper data...		Retrieve Docu...	High

Below the table is the 'Threat Properties' section for the selected threat (ID: 1). It shows the title 'Spoofing of Destination Data Store Storage', category 'Spoofing', description 'Storage may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Storage. Consider using a standard authentication mechanism to identify the destination data store.', justification, interaction 'Store Document', and priority 'High'.

SELECTED THREAT:

"Spoofing of Destination Data Store Storage" (ID: 1)

THREAD DESCRIPTION:

Storage may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Storage. Consider using a standard authentication mechanism to identify the destination data store.

RECOMMENDED SECURITY MECHANISM: Multi-Factor Authentication (MFA) with Digital Certificates

WHY DID I CHOOSE THIS MECHANISM:

1. Prevents Destination Spoofing:

The threat describes how an attacker could redirect data to a malicious storage location. MFA combined with digital certificates ensures that:

2. Two-Layer Protection:

First Layer (User Authentication): MFA verifies the user's identity before they can upload/download documents

Second Layer (Storage Verification): Digital certificates verify that the Storage database is legitimate and authorized

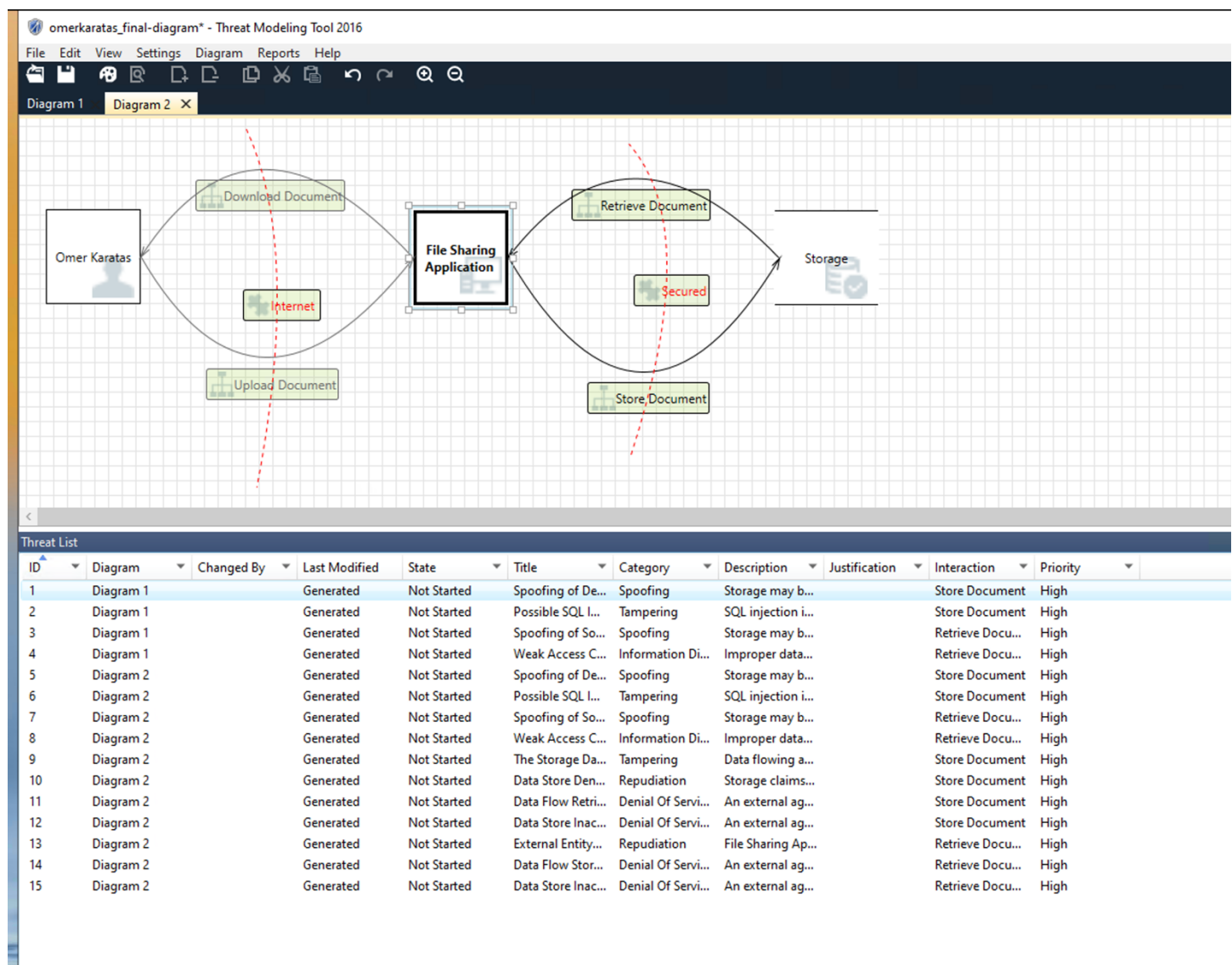
3. Prevents Man-in-the-Middle Attacks:

Digital certificates ensure encrypted communication between the File Sharing Application and Storage, preventing attackers from intercepting or redirecting data transfers.

4. Non-Repudiation:

MFA and digital certificates create an audit trail, so users cannot deny performing file operations.

Answer 1.6:



ORIGINAL DIAGRAM (Diagram 1):

Total Threats: 4

ENHANCED DIAGRAM WITH TRUST BOUNDARIES (Diagram 2):

Total Threats: 11 (Additional 7 new threats)

TRUST BOUNDARIES ADDED:

1. Trust Boundary "Internet"

- Location: Between Omer Karatas (Human User) and File Sharing Application
- Purpose: Represents unsecured internet communication path
- Represents: Public network where data may be intercepted

2. Trust Boundary "Secured"

- Location: Between File Sharing Application and Storage
- Purpose: Represents internal secured network connection
- Represents: Private internal network with security controls

STRIDE BREAKDOWN FOR DIAGRAM 2:

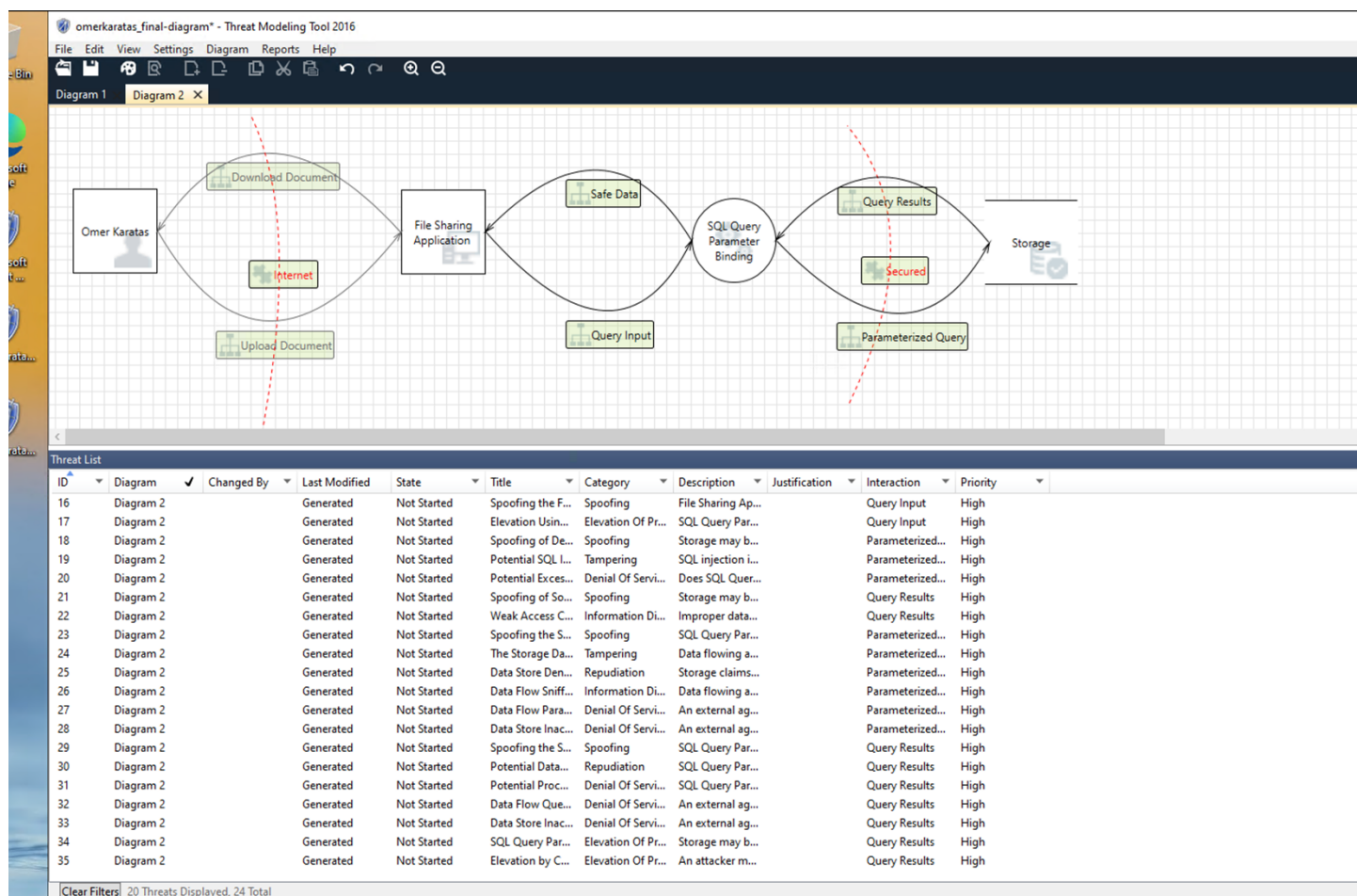
- **Spoofing:** 2 threats (IDs: 5, 7)
- **Tampering:** 2 threats (IDs: 6, 9)
- **Repudiation:** 2 threats (IDs: 10, 13)
- **Information Disclosure:** 1 threat (ID: 8)
- **Denial of Service:** 4 threats (IDs: 11, 12, 14, 15)
- **Elevation of Privilege:** 0 threats

WHY WE ADDED TRUST BOUNDARIES:

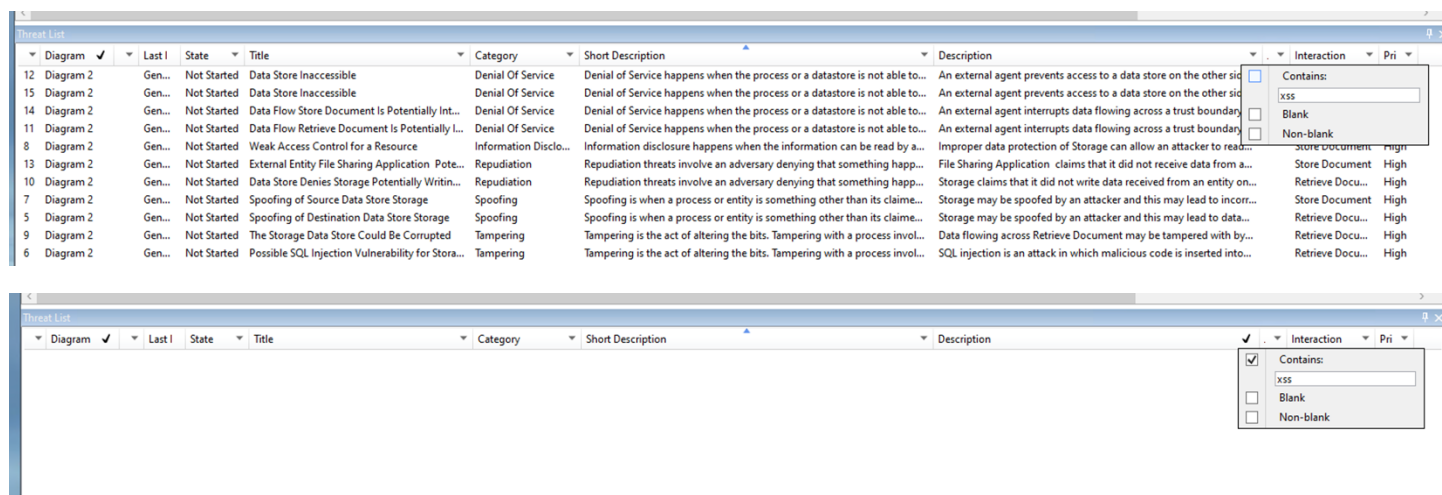
Trust boundaries define security perimeters where different trust levels exist. By adding explicit boundaries, the tool identifies more threats at the points where data crosses between trusted and untrusted zones:

- The **Internet** boundary reveals threats from unencrypted communication and public network attacks (DoS, interception)
- The **Secured** boundary reveals threats from internal access control and data integrity issues

Answer 1.7:



As seen in the images below, no XSS threats were found; therefore, we will mitigate the SQL Injection threat (ID: 6 - 'Possible SQL Injection Vulnerability for Storage').



THREAT IDENTIFIED:

"Possible SQL Injection Vulnerability for Storage" (ID: 6) Category: Tampering

SECURITY MECHANISM ADDED:

SQL Query Parameter Binding / Prepared Statements

LOCATION:

Between File Sharing Application and Storage data flow

WHY WE ADDED THIS:

SQL Injection attacks allow attackers to insert malicious code into database queries, enabling them to steal, modify, or delete sensitive data. By implementing parameterized queries, user input is treated as data only, never as executable code, preventing attackers from manipulating the SQL query structure.

HOW WE IMPLEMENTED IT:

We added a "SQL Query Parameter Binding" process component between the File Sharing Application and Storage. This component ensures all database queries use prepared statements with parameter binding instead of concatenating user input directly into SQL queries. Even if an attacker submits malicious input, it is treated as literal data and cannot alter the query logic.